

System Hardening & Windows Endpoint Security: Networking

4/18/26 11:05 AM

Summary:

- **Hardening:** Disable/remove what isn't needed (services, roles, accounts), enforce least privilege, use AppLocker/firewall.
- **Networking investigation:** Always check ARP cache, routing table, active connections, DNS cache, and hosts file.
- **Detection workflow:**
 1. Baseline with **nmap** or **ipconfig**.
 2. Disable unnecessary services/roles.
 3. Investigate anomalies (netstat -ano, Test-NetConnection, hosts file).
 4. Harden firewall and AppLocker rules.

Common Tools/Commands:

- **nmap:** Baseline open ports.
- **ipconfig /all, route print, netstat -ano.**
- **Test-NetConnection:** Port and connectivity checks.
- **nslookup:** DNS investigation.
- **ufw** (Linux firewall), **AppLocker** (Windows application control).

1. Hardening Linux Systems (Ubuntu Web Server)

Objective: Remove unnecessary services, disable root SSH, and enable firewall while keeping required web services.

Step-by-Step Hardening:

1. **Baseline scan:**
Bash
`nmap 172.31.24.10`
 - Expected open ports: 22 (SSH), 80/443 (HTTP/HTTPS), 389 (LDAP — unnecessary).
2. **Disable direct root SSH:**
Bash
`sudo vi /etc/ssh/sshd_config`
 - Change PermitRootLogin yes to PermitRootLogin no.
 - Save & exit: :wq
 - Restart SSH:
Bash
`sudo systemctl restart sshd`
3. **Disable unnecessary service (LDAP example):**
Bash
`sudo systemctl disable --now slapd.service`
`sudo apt purge slapd # Remove package and dependencies`
4. **Enable and configure firewall:**
Bash
`sudo ufw allow "Apache Full" # Allow HTTP/HTTPS`
`sudo ufw allow OpenSSH # Allow SSH`
`sudo ufw enable`
`sudo ufw status`

Verification:

Bash
`nmap 172.31.24.10`

- Port 389 should no longer be open.

Key takeaway: Always baseline with **nmap**, disable what isn't needed, and explicitly allow only required services in the firewall.

2. Hardening Windows Systems (DNS Server)

Objective: Remove unnecessary roles, harden default admin account, disable unneeded services, and restrict applications with AppLocker.

Step-by-Step Hardening:

1. **Baseline scan:**
Bash
`nmap -Pn 172.31.24.20`
 - Expected: 53 (DNS), 80 (HTTP — unnecessary), 135/3389 (RDP — lab only).
2. **Remove unnecessary role (IIS):**
 - Server Manager → Manage → Remove Roles and Features.
 - Deselect **Web Server (IIS)** → Restart server.
3. **Harden default Administrator account:**
 - Computer Management → Local Users and Groups → Users.
 - Rename Administrator to **psadmin**.
 - Set strong password.
 - Disable unneeded accounts (e.g., WDAGUtilityAccount).
4. **Disable unnecessary services:**
 - Services.msc
 - Set **ActiveX Installer, Downloaded Maps Manager, Print Spooler** to **Disabled**.
5. **Enable Application Identity service** (required for AppLocker):
 - Set to Automatic and start it.
6. **Restrict applications with AppLocker:**
 - Local Security Policy → Application Control Policies → AppLocker → Executable Rules.
 - Automatically Generate Rules for C:\Program Files.
 - Create Deny rule for specific apps (e.g., Wireshark) to test blocking.

Verification:

Bash
`nmap -Pn 172.31.24.20`

- Port 80 should no longer be open.

Key takeaway: Remove unneeded roles/services, rename/disable default admin accounts, and use **AppLocker** to control what can run.

3. Windows Endpoint Security: Networking Fundamentals

Goal: Use native Windows tools to investigate networking without third-party software (“living off the land”).

Key Commands & What They Show:

- **arp -a:** View ARP cache (IP-to-MAC mappings).
 - Add entry (for testing): arp -s 192.2.3.4 00-aa-00-62-c6-09
- **ipconfig:**
 - ipconfig /all → Full config (IP, gateway, DNS, MAC).
 - ipconfig /flushdns → Clear DNS cache.
 - ipconfig /registerdns → Register with DNS server.
- **route print:** View routing table (default gateway, persistent routes).
 - Malware can add routes for redirection.
- **ping:**
 - Test connectivity: ping 172.31.24.32
 - Options: -n 2 (send 2 packets), -t (continuous).
- **netstat -ano:**
 - Show active connections, listening ports, owning process ID.
 - Useful for spotting C2 or unexpected listeners.
- **Test-NetConnection** (PowerShell):
 - Test-NetConnection -computername badserver
 - Test-NetConnection -computername badserver -port 3389 → Test specific port.
 - -informationlevel Detailed → More info.

Hosts File (C:\Windows\System32\drivers\etc\hosts):

- Local override for DNS (maps domain to IP).
- Attackers modify it for redirection/phishing.
- Example: Add 172.31.24.32 badserver → resolves without real DNS.

nslookup:

- nslookup google.com → Resolve name.
- Inside nslookup: set type=mx → Show mail servers.
- set type=ANY → Show all records.

Security relevance:

- Check for unexpected routes, poisoned DNS cache, suspicious listening ports, or modified hosts file.
- High ephemeral ports with low packet count = normal.
- One port with massive traffic = possible C2.

Key takeaway: Use native tools (ipconfig, netstat, Test-NetConnection, nslookup) to baseline and detect anomalies without installing software.